TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Xen grant-copy flaws let a guest VM read and write other VMs' memory

From **Cybersecurity Briefing 2026-11-04** · 2026-11-03 to 2026-11-04 (last 24 hours; Indianapolis and Indiana sections cover 2026-10-30 to 2026-11-04) · Briefing generated 2026-11-04

REPORT ID	VERSION	HANDLING
CTI-20261104-01	1.0 · 2026-11-04 10:09 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-03	2026-11-04
CVES	**ANALYST**	
CVE-2026-102703, CVE-2026-102704	Nick Sturgeon	

VULNERABILITY | HIGH | PATCH AVAILABLE | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

The Xen Project published XSA-523 on 2026-11-03. It covers two flaws in grant copy, the operation Xen uses to copy data between virtual machines. To speed up batched copies, Xen caches data it has already validated, and in some cases it did not re-validate that data when it should have. CVE-2026-102703 lets frame numbers and grant references be mixed up. CVE-2026-102704 is a misplaced check that was meant to limit copy-by-frame-number to the caller's own memory. The stated impact is that a malicious guest can read and write arbitrary memory of other domains, including Dom0, the privileged control domain [S2] [S3] [S4]. Vates describes the practical result as a single compromised guest taking over the whole host [S8].

All Xen versions from 4.6 onward are vulnerable, and no mitigation is known [S2]. Upstream patches cover xen-unstable through 4.19.x and 4.18.x through 4.17.x [S2]. The first range includes the 4.20-series branches, so the briefing's wording of "4.17 to 4.19 and unstable" is narrower than the advisory; Debian and SUSE both ship fixes on 4.20 [S10] [S12]. Xen 4.6 to 4.16 get no upstream patch, and 4.16 security support ended on 2024-12-02 [S1] [S18]. That does not rule out vendor backports: SUSE lists pending fixes for its 4.16-based and 4.12-based LTSS packages [S13].

Downstream status is uneven as of 2026-11-04. XCP-ng 8.3 is fixed in xen-4.17.7-4.2.xcpng8.3 [S7]. Qubes OS 4.3 has Xen 4.19.6-3, which is moving to the stable repository over about two weeks [S9]. SLES 15 SP7 is fixed in 4.20.4_08-150700.3.52.1 [S12] [S14]. Debian bookworm, trixie and forky remain

vulnerable, with only sid fixed [S10] [S11]. Ubuntu lists its xen packages as needing evaluation [S15]. Severity ratings differ. The CVE records carry no CVSS score, Vates rates the issue Critical, and SUSE scores it 7.1 (CVSS 3.1) and 8.4 (CVSS 4.0) as Important [S3] [S4] [S7] [S12] [S13]. The briefing's High rating reflects the need for attacker control of a guest, balanced against full cross-VM impact.

No exploitation has been reported, the CVEs were not in the newest entries of the CISA KEV catalog dated 2026-11-03, and the FIRST EPSS API returned no score yet [S1] [S19] [S20]. A secondary write-up says no public proof of concept exists and that activity would look like ordinary grant-copy hypercalls, which makes after-the-fact detection hard [S16]. Organizations running Xen hosts with untrusted or multi-tenant guests should install vendor fixes and reboot hosts now, and should plan to migrate or get a vendor backport for hosts on 4.6 to 4.16. Organizations that do not run Xen directly should confirm whether any hosting provider or appliance depends on it. There is no published Indicator of Compromise (IOC) set to hunt with.

Key judgments

UNLIKELY · MODERATE CONFIDENCE
Credible in-the-wild exploitation of XSA-523 is unlikely to be publicly reported by 2026-12-04. An attacker must already control a guest on a vulnerable Xen host, the install base is narrow compared with VMware or Hyper-V, and no source reports attacks. Silent exploitation would be hard to see, so an absence of reports is weak evidence of an absence of use. [S1] [S2] [S16]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that a public proof of concept or detailed exploitation write-up appears by 2026-12-04. The fixes are small, public and name the exact functions and logic involved, which lowers the effort to reconstruct the bugs, but sources report no proof of concept so far. [S5] [S6] [S16]

VERY LIKELY · MODERATE CONFIDENCE
Debian stable releases and SUSE LTSS products will very likely receive fixed packages by 2026-11-18. Debian has already fixed sid and SUSE lists target versions for its LTSS products, so the code exists and the remaining work is packaging and testing. [S10] [S11] [S13]

ALMOST CERTAIN · HIGH CONFIDENCE
Xen hosts on 4.6 to 4.16 with no vendor backport are almost certain to stay exposed until they are migrated, because no upstream patch or mitigation exists for them. [S2] [S18]

INDICATORS OF COMPROMISE

None of the sources publish an IOC such as an IP, domain, file hash of malware or tool name, and no attacks are reported as of 2026-11-04. The two entries below are derived behavior descriptions taken from the fix commits; they are not observed attacker activity, and typical host telemetry is unlikely to expose them.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Grant-copy batch in which a frame-addressed element reuses a cached buffer left by an earlier grant-reference element`	Derived from the CVE-2026-102703 fix: the have_grant field was checked only before comparing grant references, so a leftover grant reference could be mistaken for a frame number. Observing this needs hypervisor-level tracing. Legitimate behavior of this exact form has not been characterized in the sources.	DERIVED		[S5] [S16]
other	`Grant-copy batch element that uses a frame-based reference while naming a domain other than DOMID_SELF`	Derived from the CVE-2026-102704 fix: patched Xen returns GNTST_permission_denied for this case on every batch element, while unpatched Xen enforced the check only on a conditional locking path. Observing this needs hypervisor-level tracing, and the sources do not say whether a denial is logged.	DERIVED		[S6] [S16]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attack starts from code running inside a guest on a vulnerable Xen host. The guest submits a batch of grant-copy operations. Xen keeps validated buffer state between batch elements to speed up copies in the same page, and the two flaws let a later element use that state without the checks it should get. In CVE-2026-102703, gnttab_copy_buf_valid() compared frame numbers without first confirming that the cached entry used the same addressing mode, so a stale grant reference could pass as a frame number [S5]. In CVE-2026-102704, the rule that only DOMID_SELF may copy by frame sat in a locking helper that does not run for every element, so it could be skipped; the fix moves it to gnttab_copy_claim_buf() [S6]. The result is read and write access to arbitrary memory of other domains, including Dom0 [S2]. The advisory does not state what level of access inside the guest is required [S1]. Ostorlab says only control of a guest with a working grant table is needed, with no special configuration [S16]. SUSE scores it as local with low privileges [S12]. Our inference, not stated in the sources, is that this usually means kernel or administrator control of the guest, which any hosting tenant already has over their own VM. All ATT&CK mappings below describe capability; no attacks have been observed.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Privilege Escalation	T1068 Exploitation for Privilege Escalation	Malicious guest code abuses faulty cache re-validation and a misplaced permission check in batched grant copies to gain access beyond its own domain. Mapped from the described capability; not observed in the wild. [S2] [S5] [S6] [S16]	No reliable signature is published. Grant-copy hypercalls appear ordinary on the host [S16]. Prioritize patch verification over detection.
Privilege Escalation	T1611 Escape to Host	Arbitrary write into Dom0 memory breaks guest isolation and can lead to control of the whole host, as Vates describes it. Mapped from the described capability; not observed in the wild. [S2] [S8]	Baseline Dom0 process, network and login activity, and alert on deviations such as new shells or outbound connections to non-management networks. This catches follow-on activity only, not the memory access itself.
Collection	T1005 Data from Local System	Derived from the impact statement: a malicious guest could read other domains' memory, which may hold tenant secrets. Ostorlab advises treating tenant secrets as potentially exposed on hosts that ran untrusted guests before patching. Not observed in the wild. [S2] [S16]	A cross-domain read leaves no trace the victim guest can see [S16]. Watch for later use of credentials and keys held by co-hosted VMs.
Impact	T1565.003 Data Manipulation: Runtime Data Manipulation	Derived from the impact statement: arbitrary write could alter the in-memory data of other domains, including Dom0. Not observed in the wild. [S2] [S3] [S4]	Investigate unexplained crashes or integrity failures in several VMs on one host, along with Dom0 instability. This is a weak signal and has many benign causes.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Find Xen packages not at a known fixed version `SPLUNK SPL`

```
index=inventory sourcetype=package_inventory (package="xen" OR package="xen-*")
| stats latest(version) as version latest(_time) as last_seen by host, package
| search NOT version IN ("4.17.7-4.2.xcpng8.3*", "4.19.6-3*", "4.20.4_08-150700.3.52.1*", "4.20.4+63-g7abfd2bce2-1*")
| convert ctime(last_seen)
| sort host, package
```

An exposure hunt, not an exploit detection. Adjust the index, sourcetype and field names to your inventory data, and add newer fixed builds as vendors release them. Later fixed versions will appear as false positives. Debian and Ubuntu use different package names, so review those hosts by hand.

Locate Xen software in Defender vulnerability inventory `KQL`

```
DeviceTvmSoftwareInventory
| where SoftwareName has "xen" or SoftwareVendor has_any ("xen", "xcp-ng", "vates")
| project DeviceName, OSPlatform, SoftwareVendor, SoftwareName, SoftwareVersion
| order by DeviceName asc
```

Hypervisor hosts and Dom0 often have no endpoint agent, so an empty result does not prove there is no exposure. Guest tools packages will also match. Confirm with hypervisor management consoles.

Unexpected interactive or transfer tool execution on Xen Dom0 `SIGMA`

```
title: Unexpected Shell or Transfer Tool on Xen Dom0
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  selection:
    Image|endswith:
      - '/bash'
      - '/sh'
      - '/python3'
      - '/curl'
      - '/wget'
      - '/nc'
  filter_expected_parents:
    ParentImage|endswith:
      - '/sshd'
      - '/sudo'
      - '/login'
      - '/systemd'
      - '/cron'
      - '/crond'
  condition: selection and not filter_expected_parents
falsepositives:
  - Management agents, backup tooling and update scripts on Dom0
level: medium
```

Apply only to Dom0 hosts and baseline first, because toolstack scripts will be noisy. This looks for follow-on activity and is not specific to XSA-523. Memory-only actions may leave no process event.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Xen (upstream)	4.6 and later; 4.5 and earlier not vulnerable	xsa523-1/-2.patch for xen-unstable through 4.19.x; xsa523-4.18-1/-2.patch for 4.18.x through 4.17.x; no upstream patch for 4.6 to 4.16	CVE-2026-102703, CVE-2026-102704	None in CVE records; SUSE vendor scores 7.1 (v3.1), 8.4 (v4.0)	No score returned 2026-11-04	No	N/A
XCP-ng	8.3	xen-4.17.7-4.2.xcpng8.3 (host reboot required)	CVE-2026-102703, CVE-2026-102704	Vates: Critical; CVSS 4.0 not yet available	No score returned 2026-11-04	No	N/A
Qubes OS	All supported releases and configurations (4.3 is the supported release)	Xen 4.19.6-3 in dom0 (security-testing; moving to stable over about two weeks; dom0 restart required)	CVE-2026-102703, CVE-2026-102704	Not stated	No score returned 2026-11-04	No	N/A
Debian xen package	bookworm, trixie and forky vulnerable, including current bookworm and trixie security builds	sid only: 4.20.4+63-g7abfd2bce2-1	CVE-2026-102703, CVE-2026-102704	Not stated	No score returned 2026-11-04	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
SUSE Linux Enterprise xen package	SLE 15 SP7 and LTSS products; many older products affected with no fix listed	15 SP7: 4.20.4_08-150700.3.52.1. Pending: 15 SP6-LTSS 4.18.6_03-150600.3.56.1; 15 SP5-LTSS 4.17.7_04-150500.3.85.1; 15 SP4-LTSS 4.16.7_18-150400.4.98.1; 12 SP5-LTSS 4.12.4_78-3.157.1	CVE-2026-102703, CVE-2026-102704	7.1 (v3.1), 8.4 (v4.0), SUSE: Important	No score returned 2026-11-04	No	N/A
Ubuntu xen package	Listed as needs evaluation on 16.04 through 26.10	None listed	CVE-2026-102703 (page checked for this CVE only)	None listed; Ubuntu priority Medium	No score returned 2026-11-04	No	N/A

Immediate (0–24 hours)

- Inventory every Xen-based host, including XCP-ng, XenServer, Citrix Hypervisor, Qubes and Linux distribution Xen packages, and record the Xen version and whether guests are untrusted or belong to different tenants. `xl info` or /sys/hypervisor shows the version but does not show whether the patch is applied. `IT OPS` [S2] [S16]
- On XCP-ng 8.3, install the November 2026 update so Xen reaches xen-4.17.7-4.2.xcpng8.3 or later, then reboot each host. Updates are cumulative. `IT OPS` [S7] [S8]
- On SLES 15 SP7, install SUSE-SU-2026:5087-1 and reboot into the fixed hypervisor. The reboot step is our inference: Xen is loaded at boot, and XCP-ng and Qubes both require one. `IT OPS` [S8] [S9] [S14]
- Prioritize multi-tenant hosts and hosts running guests that outside parties administer. These carry the most risk, because no mitigation is available and the tenant may already control the guest. `IT OPS` [S2] [S16]
- Ask hosting and cloud providers and appliance vendors whether their platforms use Xen and when XSA-523 fixes will be or were applied. `LEADERSHIP` [S1]

Short term (1–7 days)

- On Qubes OS 4.3, install Xen 4.19.6-3 and restart dom0. Anti Evil Maid users must reseal their secret passphrase because PCR18 and PCR19 change. `IT OPS` [S9]

- Track Debian and SUSE LTSS status daily and apply fixed packages as soon as they appear, followed by a host reboot. Do the same for Ubuntu once its evaluation completes. `IT OPS` [S10] [S11] [S13] [S15]
- If building Xen from source, update to the tip of the relevant stable branch before applying the XSA-523 patches, because the patches may not apply cleanly to the latest release tarball. Verify patch SHA256 values against the advisory. `IT OPS` [S2]
- Plan for a second XCP-ng reboot: Vates said a separate Linux kernel TCP fix would follow within about 24 hours. Do not hold the XSA-523 update for it. After rebooting, check VMs with passed-through devices, because HVM PIRQ is now off by default and can be re-enabled per VM if needed. `IT OPS` [S8]
- For hosts that ran untrusted guests before patching, assess whether tenant secrets held in co-hosted VMs warrant rotation, and ask the Xen vendor about detection support. Base the decision on the trust level of guests, since exploitation may not be detectable. `SOC` [S16]
- Confirm XSA-500 (CVE-2026-62428), the earlier grant-copy flaw, is also patched. It is a separate issue with separate patches. `IT OPS` [S1] [S17]

Long term

- Migrate workloads off Xen 4.6 to 4.16 unless a vendor provides a supported backport in writing. Upstream gives no fix for these branches. `LEADERSHIP` [S2] [S13] [S18]
- Add hypervisor versions and end-of-support dates to asset management and vulnerability scanning, including appliances that embed a hypervisor, and set a reboot-window policy for urgent hypervisor patches. `LEADERSHIP` [S18]
- Expect more frequent hypervisor advisories and keep maintenance capacity for them. The XSA-500 and XSA-523 grant-copy issues arrived about three months apart, and XSA-523 was credited to AI-assisted discovery. `LEADERSHIP` [S1] [S2] [S17]

Workarounds & compensating controls

- No technical mitigation is known. The only risk reduction until patching is to limit exposure: where possible, move untrusted or other-tenant guests off unpatched hosts, or restrict them to dedicated hosts. This reduces risk but does not fix the flaw, and live-migrating between hosts should target patched hosts only. This step is our inference from the requirement for a malicious guest. `IT OPS` [S2]
- Tighten access controls and monitoring on guests running on unpatched hosts, so an attacker is less likely to gain the foothold the flaw requires, and increase logging and network monitoring on Dom0. These measures do not address the flaw. `SOC` [S2] [S16]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Xen Hypervisor Flaws Let One Malicious VM Read and Write Any Other VM's Memory
Published 2026-11-04 · **B1** Usually reliable, confirmed by other sources
Briefing source. Summarizes downstream status and agrees with primary sources.

[S2] Xen Project: XSA-523: arbitrary read/write via grant copy (v2)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Primary advisory. Plain-text version also read for the exact patch table.

[S3] CVE Program (Xen CNA): CVE-2026-102703 record
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary record. No CVSS. Reserved 2026-09-29.

[S4] CVE Program (Xen CNA): CVE-2026-102704 record
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary record. No CVSS. Reserved 2026-09-29.

[S5] Xen Project: gnttab: complete checking in gnttab_copy_buf_valid() (xsa523-1.patch)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Fix commit for CVE-2026-102703. Defensive patch, not exploit code.

[S6] Xen Project: gnttab: move 'only local domain may copy by frame' check (xsa523-2.patch)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Fix commit for CVE-2026-102704. Defensive patch, not exploit code.

[S7] Vates: VSA-2026-055: arbitrary read/write via grant copy
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Vendor advisory. Rates Critical and names the fixed XCP-ng package.

[S8] XCP-ng: November 2026 Security and Maintenance Updates #1 for XCP-ng 8.3 LTS
Published 2026-11-03 · **A2** Completely reliable, probably true
Vendor update notes. Reboot requirement and operational side effects.

[S9] Qubes OS: QSB-121: Arbitrary read/write via grant copy (XSA-523)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Signed vendor bulletin.

[S10] Debian: Security tracker: CVE-2026-102703
Published · **A1** Completely reliable, confirmed by other sources
Live status page, read 2026-11-04.

[S11] Debian: Security tracker: CVE-2026-102704
Published · **A1** Completely reliable, confirmed by other sources
Live status page, read 2026-11-04.

[S12] SUSE: CVE-2026-102703 page
Published 2026-11-03 · **A2** Completely reliable, probably true
Vendor CVSS assessment and product status; last modified 2026-11-04. Vector marks scope unchanged.

[S13] SUSE: CVE-2026-102704 page
Published 2026-11-03 · **A2** Completely reliable, probably true
Lists pending LTSS backport versions, including 4.16 and 4.12 based packages.

[S14] SUSE: SUSE-SU-2026:5087-1: Security update for xen
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Released update for SLE 15 SP7 products.

[S15] Ubuntu: CVE-2026-102703
Published · **A2** Completely reliable, probably true
Priority Medium; all listed releases need evaluation. Live status page, read 2026-11-04.

[S16] Ostorlab: Xen Hypervisor Guest Escape (CVE-2026-102703, CVE-2026-102704)
Published · **C3** Fairly reliable, possibly true
Secondary analysis with some product marketing, stated as of 2026-11-04. Sole source for the no-PoC and no-special-configuration statements and for other hypervisors being unaffected.

[S17] Xen Project: XSA-500: grant-table: type confusion in grant-copy
Published 2026-07-28 · **A1** Completely reliable, confirmed by other sources
Related earlier flaw; publication date taken from S1.

[S18] Xen Project: SUPPORT.md for the stable-4.16 branch
Published · **A1** Completely reliable, confirmed by other sources
Xen 4.16 security support ended 2024-12-02.

[S19] CISA: Known Exploited Vulnerabilities catalog, version 2026.11.03
Published 2026-11-03 · **A2** Completely reliable, probably true
Only the first 100,000 characters, the newest entries, were read; neither CVE appeared. Full catalog not checked.

[S20] FIRST: EPSS API query for CVE-2026-102703 and CVE-2026-102704
Published · **A2** Completely reliable, probably true
Returned no records on 2026-11-04.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2024-12-02	Xen 4.16 security support ends.	[S18]
2026-07-28	Xen discloses XSA-500, an earlier and separate grant-copy flaw.	[S1] [S17]
2026-09-29	CVE-2026-102703 and CVE-2026-102704 are reserved.	[S3] [S4]
2026-11-03	XSA-523 is publicly released at 12:00 UTC. Vates, XCP-ng, Qubes and SUSE publish advisories or updates the same day.	[S2] [S7] [S8] [S9] [S14]
2026-11-04	CVE records are published. Debian shows only sid as fixed, and press coverage appears.	[S1] [S3] [S4] [S10] [S11]

Relevance to Indianapolis, Indiana & managed clients

No source reports any Indiana-specific impact or targeting. Exposure in Indianapolis and across Indiana is likely concentrated rather than broad, because Ostorlab says VMware, Hyper-V and KVM are not affected, and many small and mid-size organizations use those platforms [S16]. The groups to check first are hosting and colocation providers with shared tenants; government, education and healthcare sites with XCP-ng or XenServer clusters, including those supporting virtual desktops; manufacturers with older Xen-based virtualization that may sit on unsupported versions; and anyone relying on an appliance or hosted service built on Xen. Managed IT service clients should have their hypervisor inventory checked this week, and shared management or backup infrastructure deserves particular attention, because a guest escape on a host shared by several clients would cross client boundaries. Healthcare and public-sector organizations should involve compliance staff if a multi-tenant host with untrusted guests stayed unpatched, since memory exposure may leave no evidence. Host reboots require maintenance windows, so affected sites should schedule them now and warn clients of the possible second XCP-ng reboot [S8].

Intelligence gaps

- No CVSS from the CVE records, and NVD details could not be retrieved. Watch for an NVD assessment and EPSS scores.
- The KEV check covered the newest catalog entries only, and the catalog was dated 2026-11-03. Recheck against the live catalog.
- The exact access needed inside a guest is not stated in the advisory. Guest-type or architecture limits are also not stated: the advisory does not mention PV, HVM, x86, Arm or builds with grant tables disabled.

- XenServer and Citrix Hypervisor status is unconfirmed. Searches found no bulletin for XSA-523, and the XCP-ng notes do not say whether XenServer's 4.17.7-4 includes the fix. Ask the vendor directly.
- Status for major cloud providers and Xen-based appliances is unknown. Searches found no AWS or other provider statement on XSA-523.
- Xen 4.6 to 4.16 hosts outside SUSE have no known backport, and XCP-ng versions other than 8.3 are not addressed in the Vates advisory.
- No original technical write-up from Anthropic, Ada Logics or CodeAnt AI was found. Watch for one, and for any public proof of concept, which would raise urgency.
- No reliable method to detect past exploitation is published. Watch for vendor guidance.

Other notes

- Patch range: the advisory's table reads "xen-unstable - Xen 4.19.x", a range running from the development branch back to 4.19. Ostorlab describes this as including 4.19 to 4.22 [S2] [S16]. The briefing's excerpt reads more narrowly and should not be taken to exclude 4.20 and later.
- Unsupported branches: the absence of an upstream patch for 4.6 to 4.16 is not the same as an absence of all fixes. SUSE lists pending packages at 4.16.7 and 4.12.4 [S13]. The briefing's advice to migrate holds unless a vendor backport is available.
- Severity disagreement: Vates rates Critical while SUSE rates Important at 7.1, with a vector of unchanged scope and no subsequent-system impact [S7] [S12] [S13]. In our assessment that vector understates the stated cross-domain impact, so CVSS 7.1 should not on its own lower priority for multi-tenant hosts.
- Credit: the advisory and CVE records credit discovery to Anthropic using Claude, validation to Stephan Lipp of Ada Logics, and an independent report to the CodeAnt AI Security Research Team [S2] [S3]. The commits carry Assisted-by: Claude and Reported-by tags for Lipp and CodeAnt AI [S5] [S6].
- Minor date mismatches: the Vates page footer shows a last-updated date of 2026-11-02, before its stated 2026-11-03 publication, and SUSE's CVE page gives its advisory date as 2026-11-04 01:01 CET while the announcement page shows 2026-11-03 13:45 UTC [S7] [S12] [S14]. Neither affects the guidance.
- Known-good patch hashes (SHA256, for verifying downloads; these are benign files and must not be loaded as malicious indicators) [S2]: xsa523-1.patch 87562e68c584dcc6b568348e7ba6cfde592798cb89f372364792afda65aa6895; xsa523-2.patch 9cd4e76fa3587f491f5bb0f895f375fcf24df8bd9bdf602c343081e7411b92f0; xsa523-4.18-1.patch c1accb1fa55176cb6191e091d93198068630acbc6529966738669a43d5c2e38e; xsa523-4.18-2.patch efc16fe8830066276fb50f01f24a358194a752507077fdb61a60f891dc1a7019.

CTI-20261104-01 v1.0 · Generated 2026-11-04 10:09 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.